TICKET #007

THREE FIRES, ONE ENGINEER

Final Investigation / Incident Report

PRIMARY INCIDENT: HR-LT-44

Unexpected Word-to-PowerShell execution and external communication

Issue A | Likely Benign / Operational Process Failure

Issue B | Confirmed Security Incident in the exercise scenario

Issue C | Operational Issue with Security Follow-Up

This report distinguishes actual lab telemetry, controlled testing, and labeled scenario evidence.

Executive summary

Three different problems reached me within minutes: an unfamiliar privileged login to a production server, an HR workstation running encoded PowerShell from Word, and a customer portal returning intermittent errors. The challenge was to decide what needed me immediately, which questions could be delegated, and when new evidence justified changing course.

Issue A: The `sysadmin` login to APP-PROD-02 came from a newly provisioned administrator workstation. The account owner confirmed the session, and the reviewed privileged commands fit routine maintenance. I found no confirmed compromise. The absence of a SOC maintenance notice remains an operational control gap.

Issue B: An HR employee opened an email attachment, after which Word launched encoded PowerShell. PowerShell ran before EDR blocked a child process. HR-LT-44 subsequently reached an external destination without an established business purpose. Taken together, the scenario evidence supports treating HR-LT-44 as the primary security incident system. The reproduction used a harmless command and a controlled server; the original external communication in the scenario remains unexplained.

Issue C: The portal experienced intermittent HTTP 500 responses following a configuration change. Errors moved toward baseline after Operations rolled back, while unusual requests continued. I did not establish that the requests caused the outage or that exploitation succeeded.

No persistence, credential theft, lateral movement, or sensitive-data exfiltration was confirmed. HR-LT-51 also contacted the external destination, but a separate review did not identify the matching process chain or other supporting compromise indicators.

Priority and attention history

Time	My order	Why it changed or stayed
09:00	B → A → C	The connected HR endpoint and unusual execution needed quick clarification.
09:25	C → A → B	Customers were affected and Operations needed an immediate rollback decision.
09:40	B → C → A	Email delivery and the partial EDR block changed the endpoint risk.
10:05	B → C → A	The external connection strengthened the B incident hypothesis; A and C became less urgent.
10:50	B → C → A	A second destination match required scope validation, not automatic second-host containment.

The earlier decisions remain preserved in the repository as they were understood at each stage. The 09:25 order reflected the need for a service decision, not a conclusion that the portal was the gravest security threat.

Issue B — Initial access and process activity

Email trigger

The scenario placed the triggering email about ten minutes before the EDR alert. It displayed an executive name, but the actual sender had not initially been authenticated. The attachment was the stated source of the Word activity; the email record is a labeled scenario artifact, not a recovered corporate mailbox record.

What ran

Windows Security Event ID 4688 showed **WINWORD.EXE → powershell.exe** with an encoded command. The decoded lab command created a benign marker file. That supports a narrow conclusion about the controlled payload, not a finding that every part of the email/document event was authorized. The EDR scenario record reported a High Severity alert and a blocked child process after PowerShell had already executed.

Why I recommended containment

At 09:40 the email origin and incomplete prevention mattered more than the harmless marker alone. Keeping HR-LT-44 online created a plausible opportunity for further execution or network activity. I recommended isolation of this one workstation and preservation of the email, Windows, EDR, and connection records. The record supports a containment decision; it does not establish that a corporate EDR product was actually used to isolate the home-lab computer.

Issue B — Network, user, and data questions

External communication

The controlled server at **192.168.56.150:8088** logged a successful **GET /status.txt** and an HTTP 200 response. Because of the VirtualBox network path, the Windows lab source appeared as **192.168.56.1** in the server log. The test response was harmless. The connection validates the exercise’s outbound-connectivity condition; it cannot establish whether the scenario’s original traffic was command-and-control, payload retrieval, or data transfer.

User context and confidentiality

In a separate test, a PowerShell process launched from PowerShell read a sample HR compensation CSV. This showed that the represented user context could reach that test file, but the test process was **not** the original Word-launched one. There is no confirmed evidence that the suspicious execution accessed or transferred HR data. A data-impact review remains an action rather than a completed exfiltration finding.

Persistence, identity, and lateral movement

I checked scheduled tasks and common Run-key locations without finding a supporting persistence indicator. Queries for common credential-access and lateral-movement tooling did not produce corroborating events in the records examined. Those were bounded checks with incomplete historical visibility. They reduce the evidence for those activities; they cannot prove that nothing occurred outside the collected telemetry.

Scope decision and HR-LT-51

At first, HR-LT-44 was the only workstation tied to the suspicious process chain. The later HR-LT-51 destination match was enough to widen the investigation, so I assigned another engineer to review that host while I retained ownership of HR-LT-44 and incident coordination.

The engineer found no corresponding Word-to-PowerShell chain, High Severity EDR alert, persistence indicator, credential-access indicator, or suspicious authentication activity. The controlled connection was consistent with a user-initiated web request. I therefore did not recommend isolating HR-LT-51 solely because the destination matched. The search for related indicators across the environment should still be completed.

A shared destination can serve different applications or host legitimate and suspicious content simultaneously. A common endpoint is a lead to verify; it is not, on its own, proof of a common root cause.

Issue A — Privileged access

The initial alert showed a successful `sysadmin` SSH login from an unfamiliar internal source. At 09:18 I interrupted B because the session remained active and was issuing sudo commands on a production server. The captured commands were `sudo whoami`, `sudo touch /tmp/ticket007-privileged-marker`, and `sudo ls -ld /root`. They demonstrated root-level activity but no destructive change or persistence in the observations available.

Later source and owner checks established a newly provisioned authorized administrator workstation and routine maintenance. I stopped the primary security investigation when those facts resolved the central authorization question. Infrastructure Operations still needs to address the missing SOC maintenance entry.

Issue C — Portal outage and security follow-up

The current pre-rollback sample contained **16 HTTP 200** and **4 HTTP 500** responses out of 20 requests. The access log also showed a 500 error before the unusual requests observed in that sample. Together with the recent configuration deployment, those observations gave Operations a defensible reason to restore the known-good version rather than wait for a complete exploit investigation.

Errors improved rapidly after rollback even as unusual traffic continued. That supports the configuration change as the more likely source of the service degradation. Security should retain the web evidence and continue looking for successful exploitation indicators, but the outage itself belongs with Operations.

Coordination and ownership

Immediate work

- Security and Endpoint Support: maintain HR-LT-44 containment and preserve endpoint state.
- SOC and Email Administration: retain the message and headers and search for other recipients or openers.
- Network Engineering: look for related destination traffic and assess any proposed block for collateral impact.
- IAM: review the HR user’s sign-ins, sessions, and possible account misuse.
- HR and Endpoint Support: coordinate employee impact, data-sensitivity questions, and validated restoration.

When additional stakeholders become necessary

Legal/Privacy should be consulted if the evidence reasonably indicates exposure of sensitive employee or regulated data. Management owns resource and business-impact decisions. Communications and Vendor Management do not have a current trigger on the evidence available.

Delegation discipline

The SOC analyst’s source check, Operations’ rollback work, and the additional engineer’s HR-LT-51 review each answered a bounded question. I kept cross-incident priority, containment, and scope decisions with the incident lead so that information from different teams could be weighed together.

Final dispositions and confidence

Issue	Disposition	Confidence / remaining work
A	Likely Benign / Operational Process Failure	High confidence in the likely-benign assessment; assign maintenance-notification improvement.
B	Confirmed Security Incident in the scenario	High confidence in the scenario finding, moderate in current confirmed scope; finish endpoint, identity, email, data, and IOC checks.
C	Operational Issue with Security Follow-Up	Moderate to high that the errors were change-related; verify stable service and monitor unusual requests.

Evidence boundaries and closure conditions

This is a training investigation. The home lab generated Windows and Linux telemetry and controlled network exchanges; enterprise EDR, email, inventory, and change-management details were represented by labeled scenario records. A lack of matched events is not proof of absence, and a controlled data-access demonstration is not proof that a suspicious process stole information.

The **documentation package is complete**. Operational incident closure still depends on the assigned owners verifying HR-LT-44 remediation and a clean state, resolving identity and email reviews, finishing related-indicator searches, assigning the Issue A notification fix, confirming portal stability, and retaining the evidence. The ticket should not claim those unverified response actions are complete simply because this report has been written.

What this exercise reinforced

I learned to distinguish a dramatic alert from an urgent decision. I also learned to ask whether the next command can change what I do, to record the cost of interrupting work, and to stop investigating an issue once a supported lower-risk disposition is available. The goal was not to give every alert equal time; it was to use limited attention where it could protect the organization most effectively.